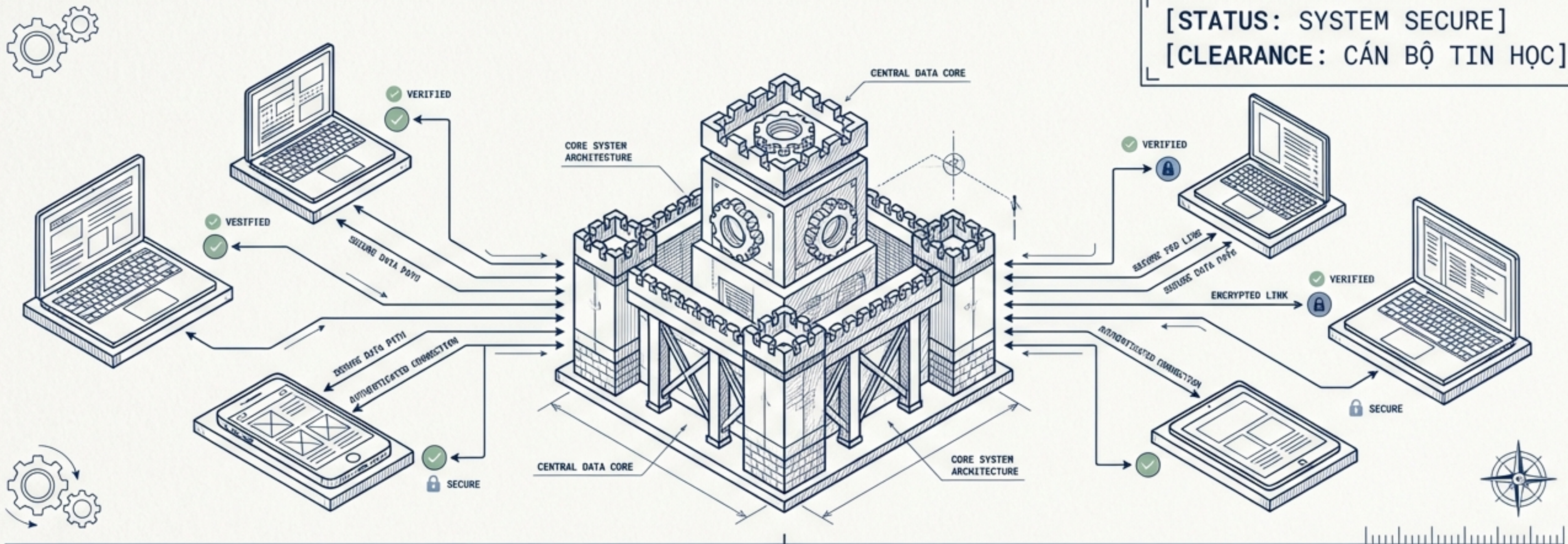


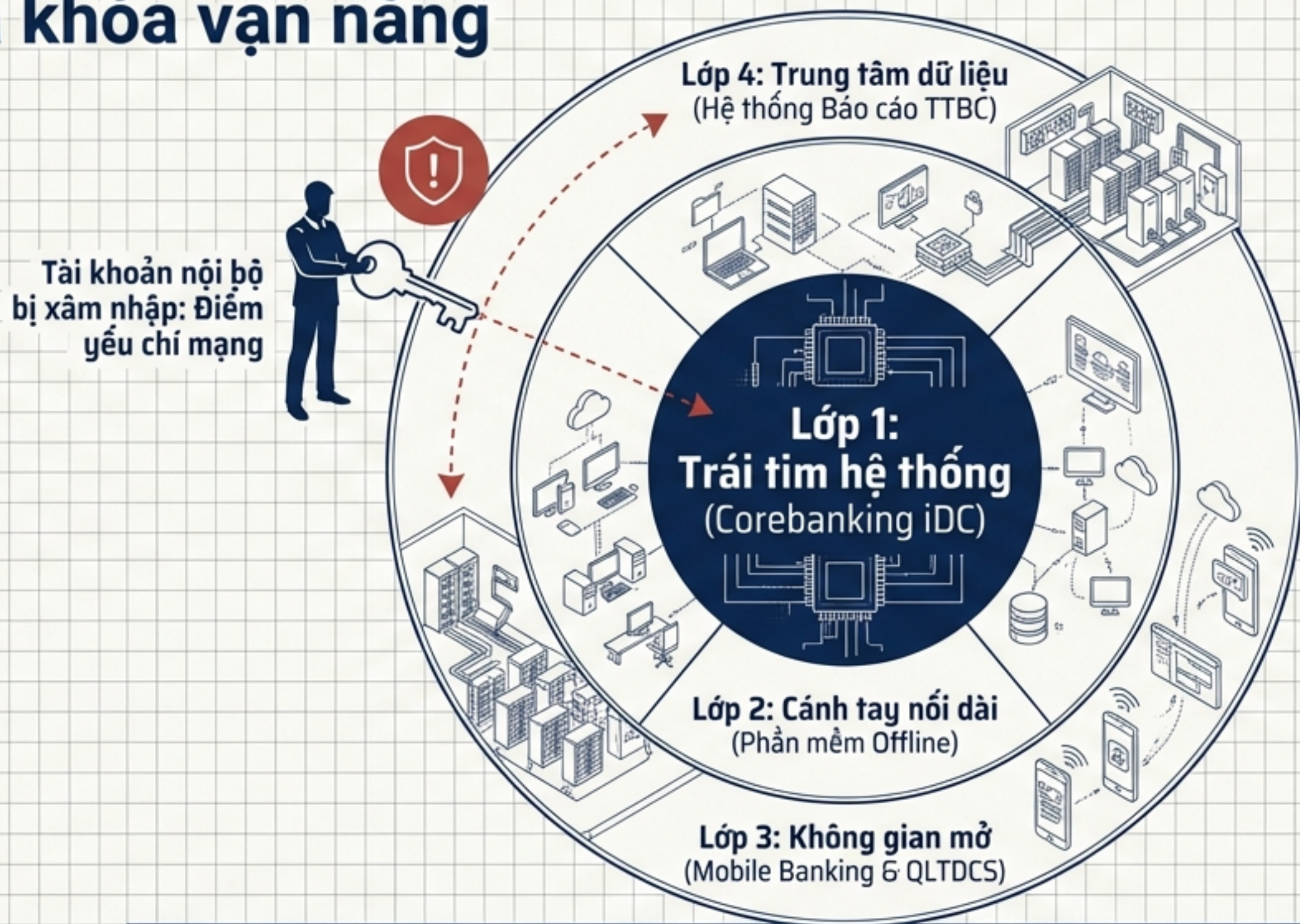


BẢO VỆ THÀNH TRÌ SỐ NHCSXH

Kỷ luật vận hành và An toàn thông tin trong Quản trị Ứng dụng Nội bộ

Bảo mật không phải là rào cản, mà là chốt chặn sinh tử bảo vệ tài sản của ngân hàng và sinh mệnh chính trị của cán bộ.

Định vị Rủi ro: Tài khoản người dùng là chìa khóa vạn năng



Dù lớp mã hóa có tối tân đến đâu, một tài khoản chia sẻ sai quy định sẽ làm sụp đổ toàn bộ pháo đài từ bên trong.

LỚP PHÒNG THỦ 1: Corebanking iDC & Xác thực Đa yếu tố

Theo QĐ 8128/QĐ-NHCS, hệ thống yêu cầu tối thiểu 2 yếu tố để chứng minh danh tính.



[1] Yếu tố Kiến thức
(Cái bạn biết):
Mật khẩu, số PIN.



[2] Yếu tố Sở hữu
(Cái bạn có):
Email nội bộ (@vbsp.vn),
OTP SMS, OTT QLTDCS.



[3] Yếu tố Sinh trắc học
(Cái bạn là):
Vân tay, khuôn mặt.

TUYỆT ĐỐI KHÔNG sử dụng email hoặc số điện thoại cá nhân để nhận OTP của hệ thống.

Vòng đời Mật khẩu iDC: Kỷ luật về thời gian

Khởi tạo
(0-5 ngày)



Đổi định kỳ
(Mỗi 90 ngày)



Khóa tự động



Dùng OTP gửi về Email
@vbsp.vn để tạo pass mới.
Khóa tài khoản nếu quá 6 ngày.

Yêu cầu độ phức tạp.
Không dùng lại pass cũ.

Hệ thống khóa khi:
Nhập sai 5 lần HOẶC
Không đăng nhập sau 30 ngày.

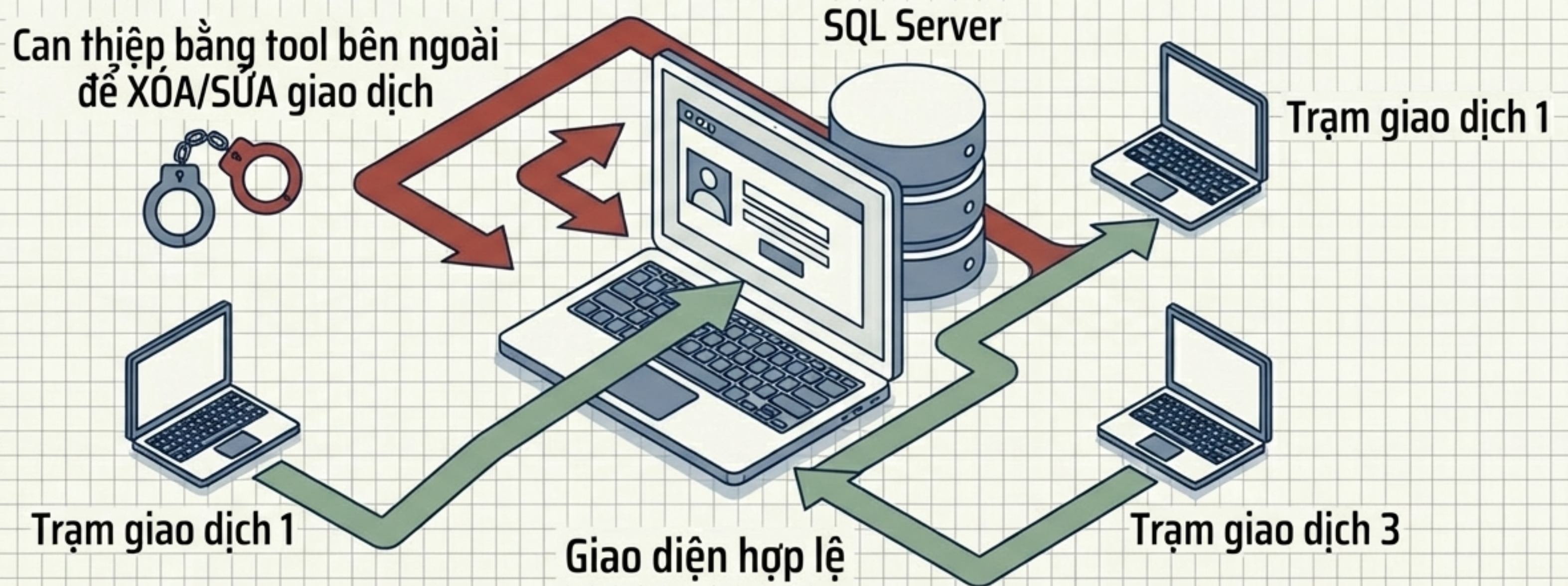


MẸO VẬN HÀNH:

Luôn **đăng xuất** và **đăng nhập lại** ngay sau khi đổi mật khẩu để kiểm tra tính hợp lệ trong môi trường an toàn.

LỚP PHÒNG THỦ 2: Giải phẫu Rủi ro CSDL Offline Dùng chung

Đặc thù: Phần mềm Offline dùng chung 1 CSDL SQL Server trên 1 laptop máy chủ tại điểm giao dịch.



CẢNH BÁO: Hành vi can thiệp vòng qua cơ chế của App là vi phạm pháp luật hình sự, gây sai lệch dữ liệu đồng bộ lên iDC.

Vận hành Offline: Ranh giới An toàn và Sai phạm



NÊN LÀM

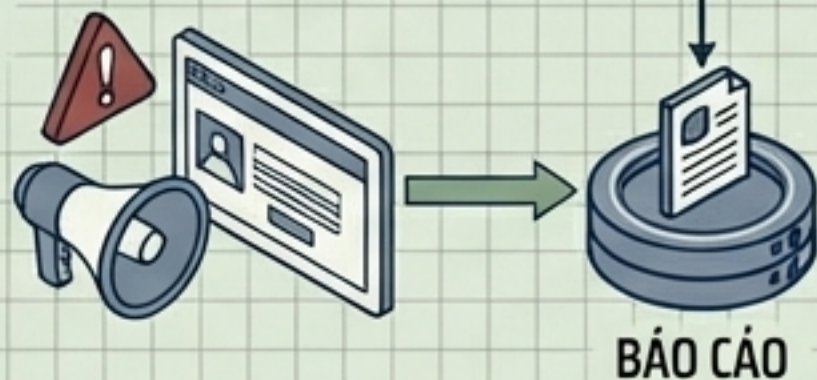
- ✓ - KSV giám sát chặt chẽ quy trình cuối ngày, xuất file mã hóa tải về iDC.



- ✓ - Admin đồng bộ người dùng đầu ngày. KSV kiểm tra kỹ CCCD/Chữ ký.

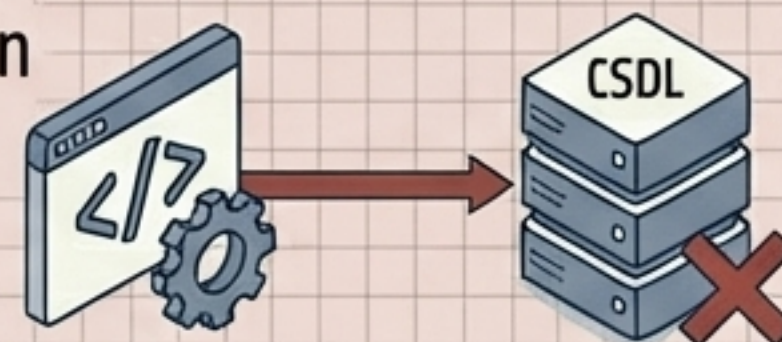


- ✓ - Báo ngay sự cố nếu phát hiện điểm giao dịch sai lệch.

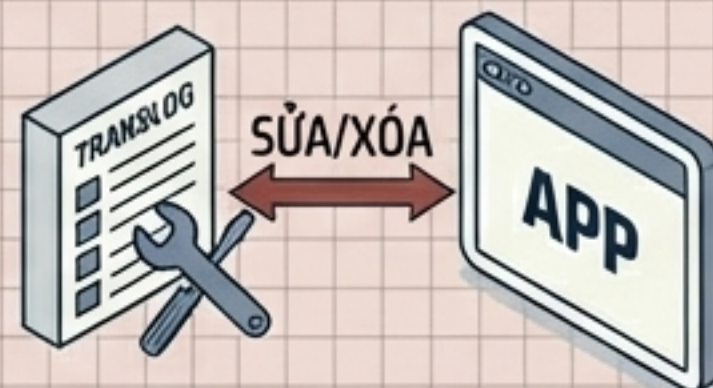


TUYỆT ĐỐI KHÔNG LÀM

- ✗ - Sử dụng tool tự phát triển can thiệp CSDL.



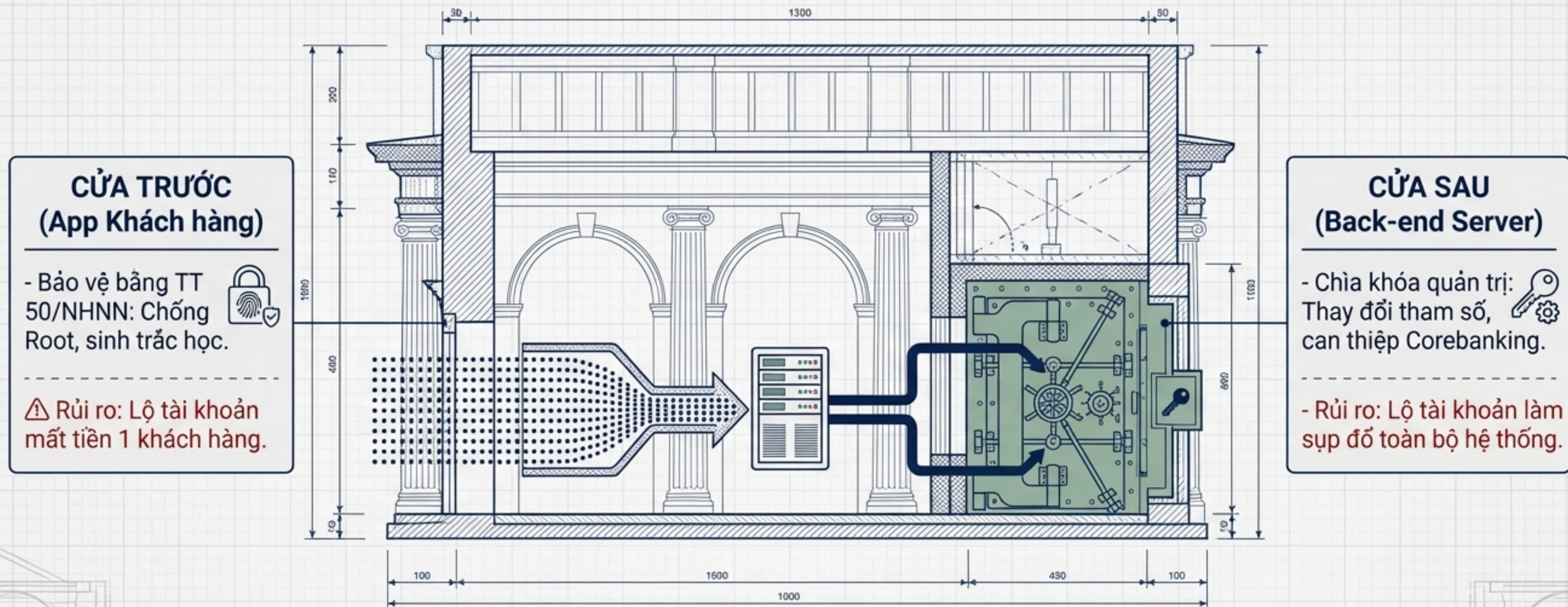
- ✗ - Sửa/xóa giao dịch ngoài giao diện chức năng của App.



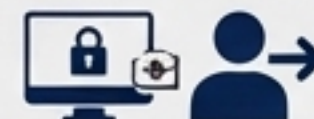
- ✗ - Sử dụng máy tính cá nhân làm máy chủ Offline.



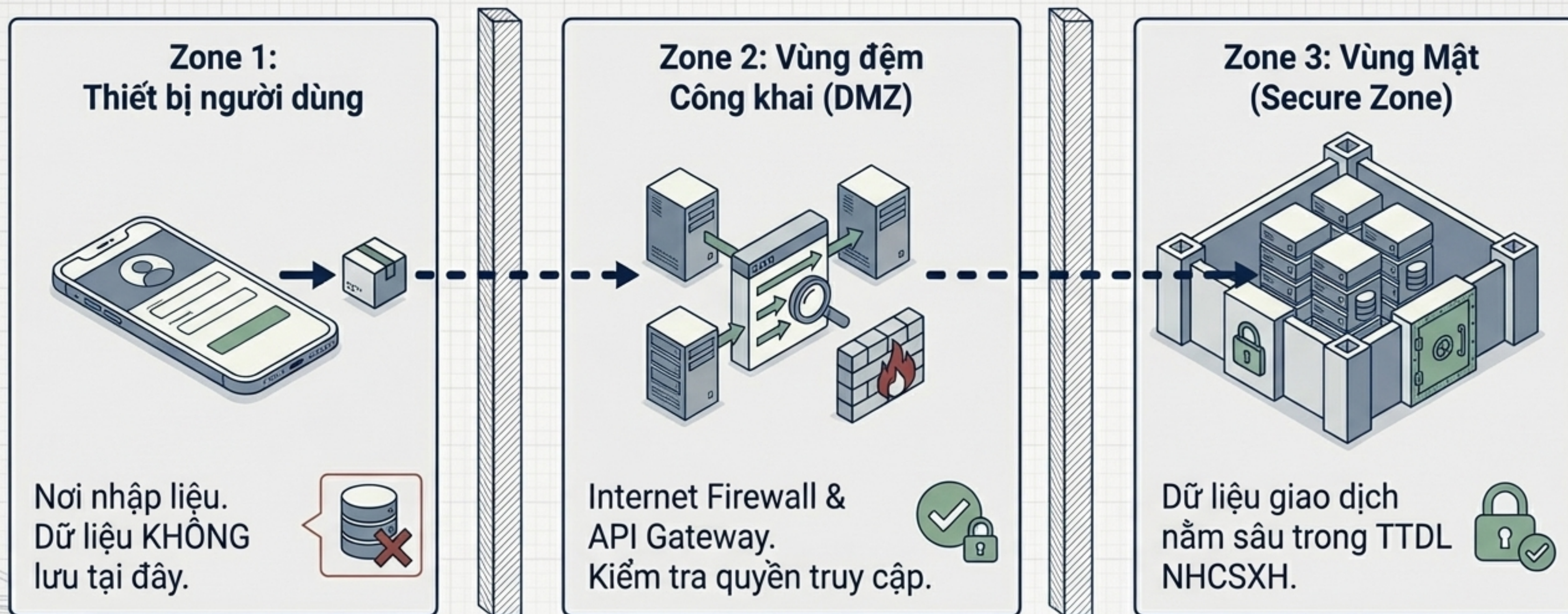
LỚP PHÒNG THỦ 3: Mô hình Cánh Cửa của Mobile Banking



NGUYÊN TẮC QUẢN TRỊ:
Không đăng nhập Back-end từ mạng công cộng, luôn Lock màn hình khi rời đi.



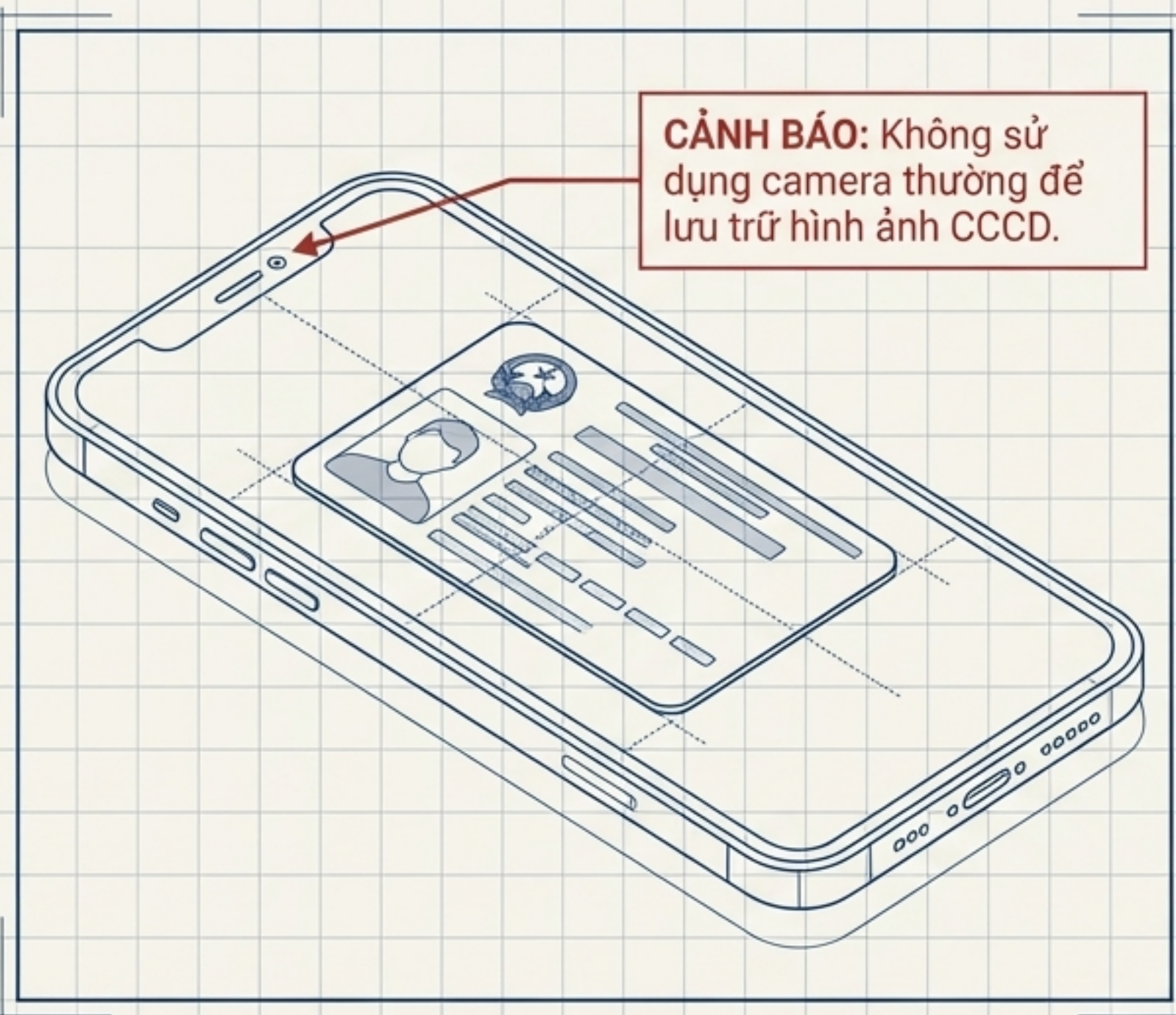
Kiến trúc 3-Zone QLTDCS: Dữ liệu nằm ở đâu?



KẾT LUẬN: Tổ trưởng ghi nhận giao dịch an toàn vì App chỉ gọi API.
Rủi ro lớn nhất là tài khoản chưa bị khóa.

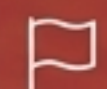


Thu thập eKYC qua QLTDCS: Nguyên tắc Không Lưu Trữ



QUY TRÌNH CHUẨN:

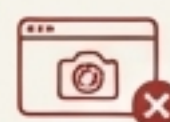
Nhập CIF → Chụp CCCD gốc →  : 
→ Quét NFC →  :  Chụp khuôn mặt 
→ Đối chiếu CSDL Bộ Công an. → 



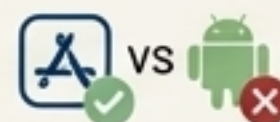
RANH GIỚI ĐỎ:



- **KHÔNG** chụp lại ảnh CCCD bằng camera thường để lưu riêng.



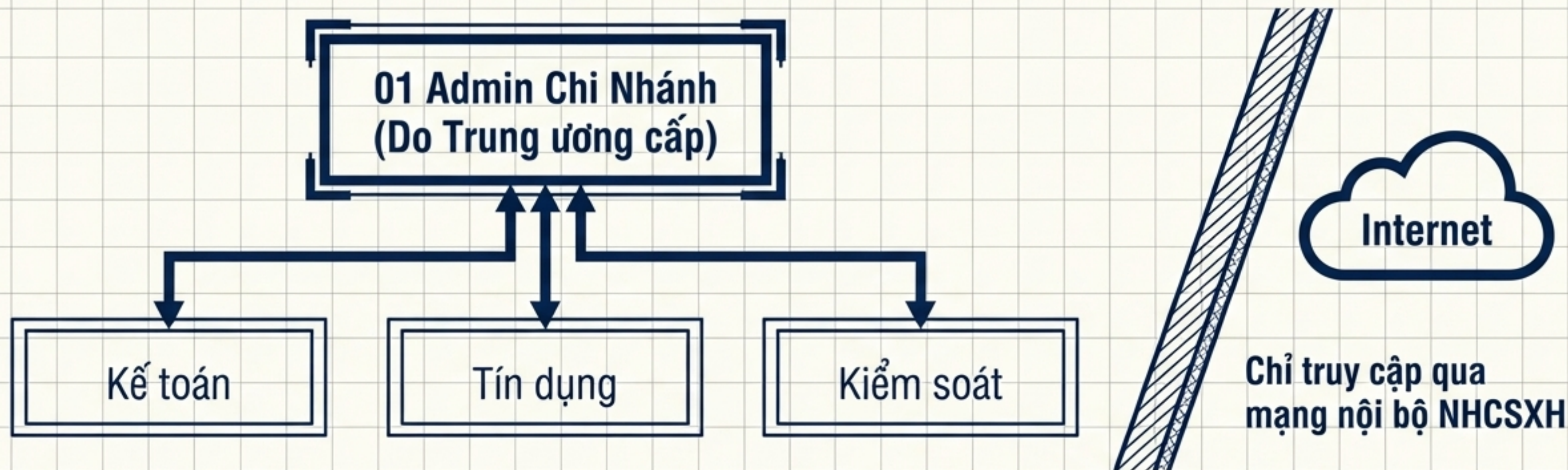
- **KHÔNG** chụp màn hình khi đang thực hiện thu thập.



- Chỉ tải App từ chợ ứng dụng chính thức, tuyệt đối không dùng file APK.

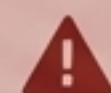
CHỈ ĐẠO: Thiết bị đã root/jailbreak sẽ bị hệ thống chặn tự động. Báo cáo sự cố mất máy trong vòng 30 phút.

LỚP PHÒNG THỦ 4: Hệ thống Báo cáo (TTBC) - Quyền lực của Admin



NHIỆM VỤ CỦA ADMIN:

- Cấp đúng quyền (Không cấp dư quyền xem CIC).
- Không tự cấp quyền Admin cho bản thân/người thân.
- Khóa/Thu hồi user ngay trong ngày khi nhân sự nghỉ việc.



VI PHẠM NGHIÊM TRỌNG:

Xuất file báo cáo nhạy cảm ra thiết bị lưu trữ ngoài hoặc mạng lưới cá nhân.

Hệ sinh thái Nội bộ: Tài khoản riêng - Quản lý riêng - Bảo vệ riêng



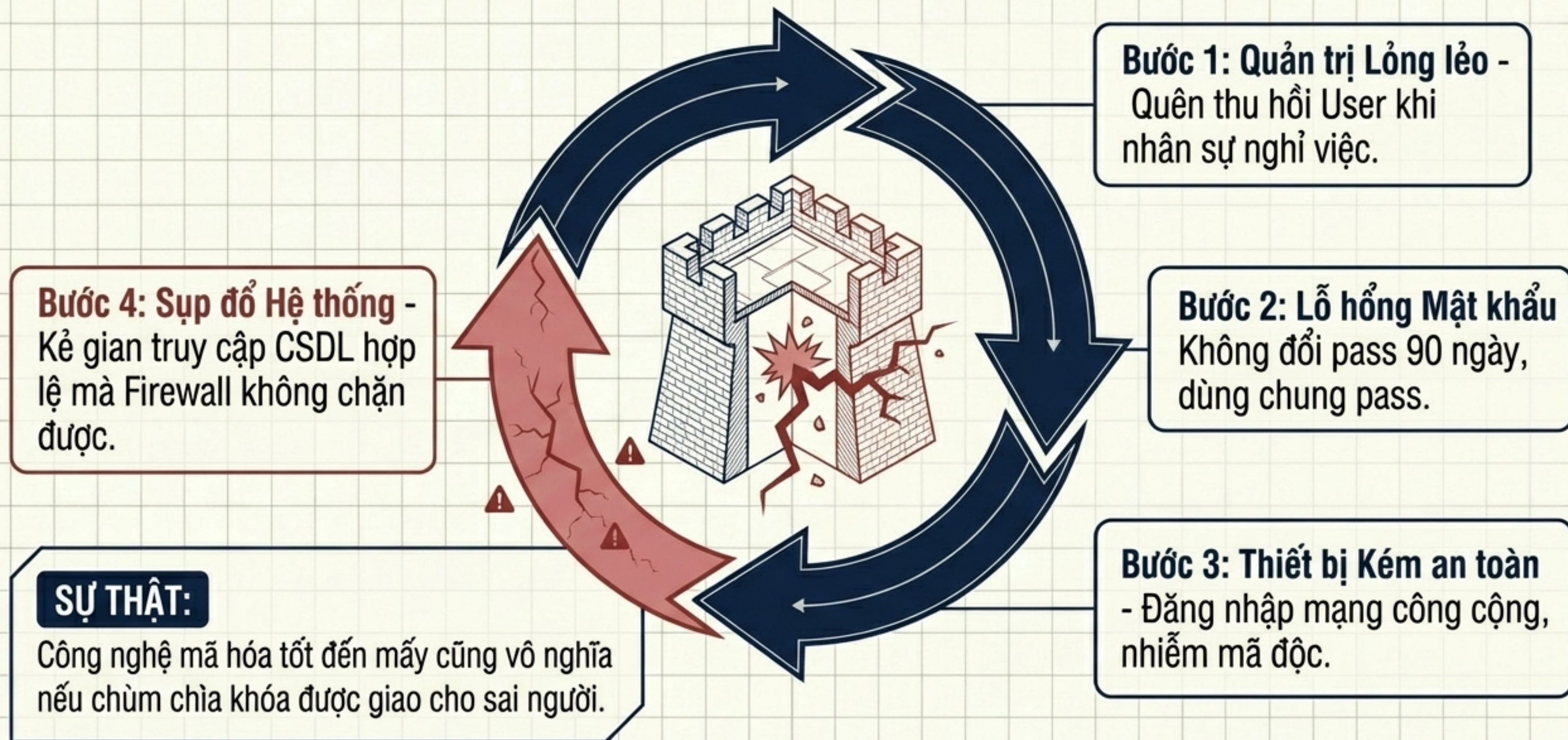
- **BẢN CHẤT HỆ THỐNG:**
Không có xác thực tập trung (SSO) toàn hệ thống. Mỗi phần mềm quản lý tài khoản hoàn toàn độc lập.
- **RỦI RO:**
Dùng chung 1 mật khẩu cho nhiều nền tảng dẫn đến việc 1 hệ thống lộ lọt sẽ làm toàn bộ hệ sinh thái bị xâm nhập.
- **QUY TRÌNH BẮT BUỘC:**
Admin phải đi từng hệ thống để khóa tài khoản khi có biến động nhân sự. Không được bỏ sót!

⚠ LƯU Ý: File Excel danh sách nội bộ trích xuất phải có dấu hiệu cấm phát tán, không chia sẻ qua các ứng dụng OTT cá nhân.

Ma Trận Nhận Diện Rủi Ro Hệ Thống

Hệ thống	Dữ liệu Nhạy cảm	Rủi ro Con người Lớn nhất	Biện pháp Chốt chặn
 Corebanking iDC	Toàn bộ DL Ngân hàng	Chia sẻ OTP, mượn user	MFA, Đổi pass 90 ngày
 Phần mềm Offline	Tiền mặt, GD đầu ngày	Can thiệp trực tiếp SQL	Đồng bộ Admin, Cấm Tool
 Mobile Back-end	Tham số hệ thống, ESB	Đăng nhập mạng lạ, quên Logout	Thông tư 50, Isolation
 QLTDSC Mobile	eKYC, Thông tin khoản vay	Lưu ảnh CCCD trên máy	API Gateway 3-Zone
 Báo cáo TTBC	CIC, Thông tin cá nhân	Quên thu hồi user khi nghỉ việc	1 Admin phân quyền

Vòng Đời Rủi Ro Của Một Tài Khoản





KỶ LUẬT SẮT TRONG VẬN HÀNH

1. Xác thực 2 lớp là khiên chắn, tuyệt đối không chia sẻ OTP.
2. Không can thiệp CSDL Offline bằng bất cứ giá nào.
3. Thu hồi quyền truy cập ngay trong ngày khi có thay đổi nhân sự.

Bảo mật không nằm ở máy chủ trung tâm. Bảo mật nằm ở ngón tay người gõ phím. Bạn là người gác đền của NHCSXH.